

Аудит IT-инфраструктуры — ООО «СтимАналитика»

Задание 5 «Управление IT-проектами»

1. Описание предприятия

1.1 Общая информация о компании

Название: ООО «СтимАналитика»

Сфера деятельности: Разработка и эксплуатация SaaS-сервиса прогнозирования цен на виртуальные предметы торговой площадки Steam

Размер: 6 штатных сотрудников (+ привлечение подрядчиков на старте)

Роль	Кол-во	Занятость
Владелец / Product Owner	1	1.0 FTE
Backend-разработчик	1	1.0 FTE
ML-инженер	1	0.5 FTE
DevOps-инженер	1	0.25 FTE
Аналитик данных	1	0.5 FTE
Оператор системы / Support	1	0.5 FTE

Краткое описание: Компания разрабатывает и поддерживает веб-сервис **Steam Market**

Price Predictor — аналитический SaaS-продукт, предоставляющий трейдерам и коллекционерам прогнозы изменения цен на скины CS2, Dota 2, TF2 и Rust на основе 17 прогнозных моделей (ARIMA, SARIMA, Prophet, XGBoost, LightGBM, CatBoost, LSTM и др.) с открытым бэктестингом и AI-анализом через LLM (Anthropic Claude, Groq).

1.2 Основные бизнес-процессы, зависящие от IT

Процесс 1 — Сбор и хранение ценовых данных

Ежедневный автоматический сбор исторических цен на 17+ предметов через Steam Web API с записью в PostgreSQL и архив scraped_data/. Без этого процесса невозможно обучение и валидация прогнозных моделей.

Процесс 2 — Прогнозирование и аналитика для пользователей

Предоставление пользователям прогнозов цен через веб-интерфейс и REST API: выбор модели, горизонт прогноза, бэкестинг с метриками MAE/RMSE/MAPE, AI-анализ через LLM. Основной value proposition продукта.

Процесс 3 — Монетизация и клиентское обслуживание (B2C + B2B)

Управление подписками Premium, биллинг, обработка API-запросов от B2B-клиентов, техподдержка пользователей, мониторинг SLA. Формирует выручку компании (MRR, ARR).

1.3 Роль IT в бизнес-процессах

Процесс 1 — Сбор данных

IT-система	Роль в процессе	Метрики мониторинга
Steam Web API + steam_client.py	Единственный источник ценовых данных; HTTP-запросы, обработка rate-limit, хранение cookie	Success Rate $\geq 95\%$ (Норма), предупреждение $< 95\%$, критично $< 80\%$
PostgreSQL (managed)	Хранение временных рядов цен, метаданных предметов	Доступность БД $\geq 99.5\%$, время запроса ≤ 200 мс, объём данных (GB) с алертом при $> 80\%$ диска
S3-совместимое хранилище (scraped_data/)	Ежедневные снапшоты для бэкестинга и восстановления (RPO ≤ 24 ч), retention 30 дней	Статус последнего бэкапа, объём архива, возраст свежайшего снапшота (алерт если > 26 ч)

Процесс 2 — Прогнозирование и аналитика

IT-система	Роль в процессе	Метрики мониторинга
FastAPI backend (main.py , prediction.py)	Обработка запросов /api/predict, /api/backtest, /api/history; запуск 17 моделей	Uptime $\geq 99.5\%$; Error Rate $\leq 2\%$ (норма), $> 5\%$ (warn), $> 10\%$ (critical); Время ответа /api/predict ≤ 10 с (норма), > 30 с (critical)
ML-пайплайн (prediction.py , MinMaxScaler , date- based features)	Feature engineering, обучение и инференс 17 моделей	MAPE $\leq 10\%$ (норма), $> 15\%$ (warn), $> 25\%$ (critical); еженедельный авто-бэкстест по топ-20 предметам[^4]
LLM API (Anthropic Claude / Groq)	AI-интерпретация прогнозов для Premium- пользователей	Latency LLM-ответа (норма ≤ 5 с, warn > 10 с), доля ошибок LLM API (norm $\leq 1\%$, critical $> 5\%$), месячный расход токенов vs бюджет
Grafana + Prometheus + Alertmanager	Визуализация всех метрик, алерты в Telegram/Email	Задержка поступления метрик $\leq$ 30 с; доступность Grafana $\geq 99\%$; количество ложных срабатываний алертов (< 5 /нед в норме)

Процесс 3 — Монетизация и поддержка

IT-система	Роль в процессе	Метрики мониторинга
------------	-----------------	---------------------

Биллинговая система + PostgreSQL (подписки)	Управление тарифами, обработка платежей Premium (500 руб/мес), генерация API-ключей B2B	Доступность биллинга $\geq 99.9\%$; задержка активации подписки ≤ 5 мин; число failed-транзакций (алерт > 3 /час)
Service Desk / тикет-система (Telegram-бот / Jira)	Обработка обращений B2B-клиентов ≤ 8 рабочих часов, feedback пользователей ≤ 24 ч	Среднее время первого ответа (FRT); доля тикетов, закрытых в SLA; количество открытых тикетов старше 48 ч

2. Инвентаризация IT-инфраструктуры

2.1 Аппаратное обеспечение (серверы и рабочие станции)

№	Наименование / Назначение	Тип	Конфигурация	ОС	Статус
1	VPS Production (Backend + API)	Виртуальный сервер (облако)	4 vCPU, 8 GB RAM, 80 GB SSD	Ubuntu Server 22.04 LTS	В эксплуатации
2	VPS Staging / Test	Виртуальный сервер (облако)	2 vCPU, 4 GB RAM, 40 GB SSD	Ubuntu Server 22.04 LTS	В эксплуатации
3	Managed PostgreSQL	Облачная БД (managed service)	2 vCPU, 4 GB RAM, 50 GB SSD	Управляется провайдером	В эксплуатации
4	S3-совместимое объектное хранилище	Облачное хранилище	до 100 GB	Управляется провайдером	В эксплуатации

5	CDN (статика frontend)	Облачный CDN	Edge-точки провайдера	Управляется провайдером	В эксплуатации
6	CI/CD Runner (GitHub Actions / GitLab Runner)	Виртуальный (облачный)	Shared runner провайдера	Ubuntu 22.04	В эксплуатации
7	Рабочая станция Backend-разработчика	Ноутбук (физический)	Intel Core i7-12th, 32 GB RAM, 512 GB SSD	Windows 11 Pro + WSL2 (Ubuntu 22.04)	В эксплуатации
8	Рабочая станция ML-инженера	Ноутбук (физический)	Apple M2 Pro, 16 GB RAM, 512 GB SSD	macOS Ventura 13.x	В эксплуатации
9	Рабочая станция DevOps-инженера	Ноутбук (физический)	Intel Core i5-12th, 16 GB RAM, 256 GB SSD	Ubuntu 22.04 LTS Desktop	В эксплуатации
10	Рабочая станция Аналитика данных	Ноутбук (физический)	Intel Core i5-11th, 16 GB RAM, 256 GB SSD	Windows 11 Pro + WSL2	В эксплуатации
11	Рабочая станция Оператора / Support	Ноутбук (физический)	Intel Core i3-11th, 8 GB RAM, 256 GB SSD	Windows 11 Pro	В эксплуатации

12	VPS Мониторинга (Grafana + Prometheus)	Виртуальный сервер (облако)	2 vCPU, 4 GB RAM, 40 GB SSD	Ubuntu Server 22.04 LTS	В эксплуатации
----	---	-----------------------------------	-----------------------------------	-------------------------------	-------------------

Оценка состояния аппаратного обеспечения

На текущем этапе (Y1, MAU ~ 3 тыс.) производительности инфраструктуры **достаточно**. VPS Production (4 vCPU / 8 GB RAM) обеспечивает работу FastAPI + Docker Compose с запасом при ожидаемой нагрузке до 300 одновременных пользователей. Managed PostgreSQL с 50 GB SSD перекрывает потребности хранения временных рядов на горизонте 2+ лет. **Узкие места:** при росте до Y2 (MAU ~ 10 тыс.) потребуется вертикальное масштабирование VPS до 8 vCPU / 16 GB RAM и увеличение объёма managed PostgreSQL — это уже заложено в OPEX Y2 (30 тыс. руб/мес). LSTM и SARIMA при одновременных запросах нескольких пользователей могут исчерпывать CPU VPS Production, что зафиксировано как риск в алертах (время ответа /api/predict > 30 с).

2.2 Программное обеспечение

Категория	Название / версия	Лицензия / модель доступа
ОС серверов	Ubuntu Server 22.04 LTS	Бесплатная (Canonical)
ОС рабочих станций	Windows 11 Pro	ОЕМ-лицензии производителя ноутбуков
Контейнеризация	Docker Engine 25.x + Docker Compose 2.x	Apache 2.0 (бесплатно)
СУБД	PostgreSQL 15 (managed)	PostgreSQL Licence (бесплатно); managed-сервис оплачивается по подписке провайдера

Backend-фреймворк	Python 3.11 + FastAPI 0.111	MIT (бесплатно)
ML-библиотеки	scikit-learn, XGBoost, LightGBM, CatBoost, TensorFlow/Keras (LSTM), statsmodels (ARIMA/SARIMA), Prophet	Apache 2.0 / MIT (бесплатно)
Мониторинг	Prometheus 2.x + Grafana Cloud (Free tier Y1, Pro Y2+)	Grafana Cloud Free: до 10 000 метрик бесплатно; Pro: 5 USD/мес ^[2]
Алертинг	Alertmanager + Telegram Bot API	Apache 2.0 (бесплатно)
Трекинг ошибок	Sentry (Developer Free → Team Y3)	Free до 5 тыс. событий/мес; Team ~26 USD/мес ^[2]
LLM API	Anthropic Claude (API) + Groq API	Pay-per-use: Claude Sonnet ~\$3 input / \$15 output за 1M токенов; Groq — free tier 14k токенов/мин ^[2]
CI/CD	GitHub Actions	Free для public repos; платные минуты для private
IDE / инструменты разработки	JetBrains PyCharm / VS Code	PyCharm: лицензия IDE ~69 USD/год; VS Code — бесплатно
Офисные приложения	Microsoft 365 Business Basic	~6 USD/пользователь/мес (корпоративная подписка)
VPN-клиент	WireGuard	GPLv2 (бесплатно)

Антивирус / EDR	Windows Defender (встроен) + Bitdefender GravityZone (серверы)	Windows Defender — бесплатно; Bitdefender — ~30 USD/endpoint/год
------------------------	--	--

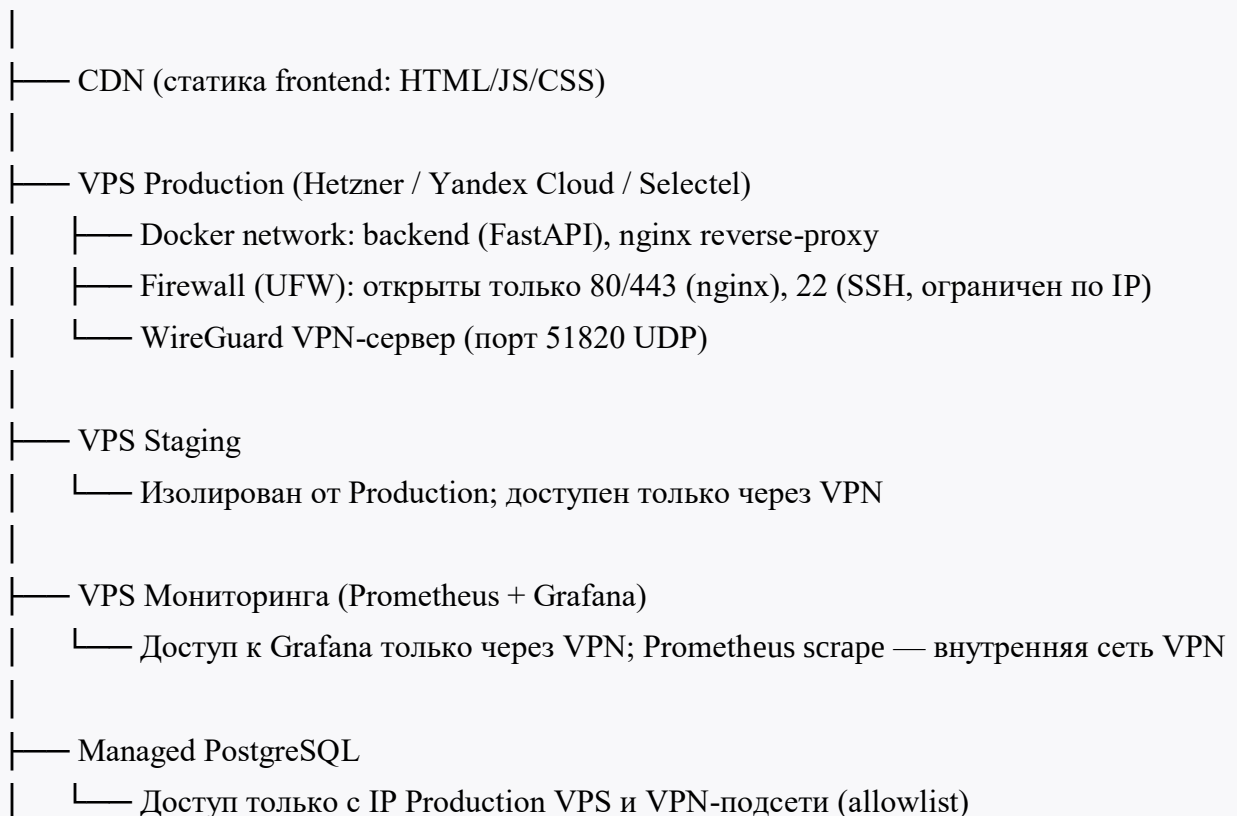
Обеспечение лицензий: Облачные сервисы (Grafana, Sentry, LLM API, GitHub Actions) оплачиваются по подписке через корпоративную карту с автоматическим продлением. Расходы фиксируются в статье OPEX «Мониторинг и логирование» и «Прочее» согласно ТСО-модели. Контроль лицензий ведётся в таблице учёта ПО DevOps-инженером; пересмотр — ежеквартально.^[^2]

2.3 Сетевая инфраструктура

Компания работает в формате **fully remote**: единого физического офиса нет, все сотрудники подключаются удалённо.

Сегментация и топология:

Интернет



- |
 - └─ S3 Object Storage
 - └─ Доступ через S3 API с IAM-токенами, HTTPS only

Удалённый доступ: все сотрудники подключаются к серверной инфраструктуре исключительно через WireGuard VPN. SSH-доступ к VPS ограничен IP-адресами VPN-подсети (firewall rule). Прямой SSH с публичного интернета заблокирован.

Интернет-подключение: каждый сотрудник использует домашнее широкополосное подключение (100+ Мбит/с). Критичных требований к latency нет: вся боевая инфраструктура — облачная.

DNS: домен зарегистрирован у регистратора (reg.ru), DNS-записи управляются через панель провайдера; TTL — 300 с для оперативного переключения при инцидентах.

3. Безопасность IT-инфраструктуры

3.1 Анализ рисков безопасности

№	Угроза	Вероятность	Потенциальный ущерб
Угроза 1	Компрометация учётных данных DevOps / SSH-ключей (брутфорс, фишинг, утечка через репозиторий)	Средняя	Полный доступ к VPS Production: удаление данных, внедрение вредоносного кода, утечка API-ключей (Steam, Anthropic, Groq, PostgreSQL). Финансовый ущерб: потеря дохода на период восстановления (до 30 дней) + репутационный ущерб → отток пользователей. Нарушение SLA Uptime (downtime > RTO 30 мин)

Угроза 2	Утечка базы данных пользователей (SQL injection, мисконфигурация PostgreSQL, компрометация managed-сервиса)	Низкая– Средняя	Утечка email, истории запросов, информации о подписках Premium, API-ключей B2B-клиентов. Юридический ущерб: нарушение ФЗ-152 (персональные данные), штрафы, иски. Коммерческий ущерб: расторжение B2B-контрактов, churn Premium-подписчиков. Репутационный ущерб — критичен для стартапа в стадии product-market fit
Угроза 3	DDoS-атака / перегрузка API (целенаправленная или конкурентная атака на публичные эндпоинты FastAPI)	Средняя	Downtime сервиса: нарушение SLA Uptime $\geq 99.5\%$ и Error Rate. Прямые потери: пропущенные ценовые данные (RPO) → снижение MAPE → отток пользователей. Финансовые потери при Uptime $< 99\%$ → нарушение SLA с B2B-клиентами → штрафные санкции
Угроза 4	Утечка / кража Steam API cookie или API-ключей LLM (хранение в незащищённых env-файлах, .git-репозитории)	Средняя	Блокировка аккаунта Steam (403/429): полная остановка сбора данных, деградация MAPE → нарушение SLA. Перерасход LLM API бюджета (несанкционированное использование ключей Anthropic/Groq)

3.2 Оценка существующих мер безопасности

Мера безопасности	Реализация в ООО «СтимАналитика»	Эффективность против выявленных угроз
Межсетевой экран (Firewall)	UFW на VPS: открыты только 80, 443, 51820 (WireGuard); SSH (22) — только с VPN-подсети	Закрывает Угрозу 1 (брутфорс SSH) частично; не защищает от DDoS на 443
VPN для удалённого доступа	WireGuard; все административные подключения только через VPN	Снижает Угрозу 1; Prometheus / Grafana доступны только из VPN-подсети
Управление секретами	.env-файлы на серверах (не в репозитории); GitHub Secrets для CI/CD	Частично снижает Угрозу 4; нет централизованного vault (HashiCorp Vault / Yandex Lockbox) — пробел
Аутентификация (MFA)	GitHub: MFA включён для всех участников организации; VPS SSH: только ключи (пароль отключён)	Снижает Угрозу 1; MFA отсутствует для доступа к панели управления облачного провайдера — пробел
Резервное копирование	Ежедневный snapshot scraped_data/ в S3 (retention 30 дней); managed PostgreSQL имеет встроенные бэкапы провайдера	Снижает последствия Угроз 1, 2; RPO ≤ 24 ч соответствует SLA[^3]; нет регулярного тестирования восстановления — пробел

Антивирус / защита рабочих станций	Windows Defender на ноутбуках Windows; отдельный EDR на серверах не развёрнут	Частично снижает Угрозу 1; серверы не имеют агентного EDR — пробел
Мониторинг и алертинг	Prometheus + Alertmanager + Grafana; алерты в Telegram/Email при критических порогах	Снижает MTTD для Угрозы 3 (DDoS) — алерт при Error Rate > 10%; Uptime < 99%; не охватывает аномалии безопасности (SIEM отсутствует)
Парольная политика	SSH: только ключи; GitHub: MFA; сервисные пароли генерируются случайно (не менее 20 символов)	Снижает Угрозы 1, 2; нет формального регламента ротации паролей и API-ключей
Обновление ПО	unattended-upgrades на Ubuntu (security patches автоматически)	Базовая защита от известных CVE; нет процедуры проверки зависимостей Python (Dependabot / pip-audit)

Вывод по достаточности мер: Базовый уровень безопасности обеспечен (VPN, SSH-ключи, firewall, бэкапы, MFA на GitHub). Для стадии MVP и MAU Y1 это приемлемо.

Ключевые пробелы для устранения до Y2 (рост B2B-сегмента, обработка персональных данных):

- Централизованное управление секретами (Vault / Lockbox)
- MFA для панели облачного провайдера
- Регулярные учения по восстановлению из бэкапа (DR drill — 1 раз в квартал)
- Мониторинг безопасности на уровне приложения (rate-limiting на API, WAF перед nginx)

- Процедура ротации Steam cookie и API-ключей (раз в 90 дней, регламент)

4. Рекомендации по управлению проектом внедрения

Проект: **Коммерческий запуск и масштабирование Steam Market Price Predictor**
(переход от прототипа к production-ready SaaS).

4.1 Цели и задачи проекта

Цель проекта: Осуществить переход функционального прототипа Steam Market Price Predictor от стадии MVP к полноценному коммерческому продукту с production-инфраструктурой, системой монетизации и ITIL-процессами управления, обеспечив устойчивую работу сервиса при MAU 3 000 к концу Y1 и выход на окупаемость в Y2.

Задачи проекта:

1. Финализировать MVP: UI, система аккаунтов, биллинг Premium (500 руб/мес), API-ключи для B2B
2. Мигрировать инфраструктуру с локального Docker Compose на облачный VPS + managed PostgreSQL + CDN
3. Развернуть систему мониторинга (Prometheus + Grafana) и алертинга с Runbook для операционной команды
4. Внедрить ITIL-процессы: управление инцидентами, изменениями, уровнем услуг
5. Обеспечить соответствие SLA: Uptime $\geq 99.5\%$, MAPE $\leq 10\%$, RTO ≤ 30 мин, RPO ≤ 24 ч
6. Закрыть выявленные пробелы безопасности (MFA для облачной панели, централизованный vault, DR drill)
7. Провести маркетинговый запуск и привлечь первых платящих пользователей

4.2 План проекта

№	Этап	Содержание	Сроки	Результат
---	------	------------	-------	-----------

1	Аудит и подготовка	Инвентаризация текущей инфраструктуры (настоящий документ); анализ рисков безопасности; определение требований к production-среде; утверждение архитектуры	Месяц 1	Документ аудита, архитектурная схема, план миграции
2	Разработка и инфраструктура	Финализация MVP (UI, аккаунты, биллинг); настройка CI/CD; деплой на облачный VPS; настройка managed PostgreSQL; развёртывание CDN; устранение пробелов безопасности	Месяцы 2–5	Production-окружение, staging-окружение, CI/CD pipeline, прохождение чеклиста безопасности
3	Мониторинг и ITIL	Развёртывание Prometheus + Grafana + Alertmanager; настройка алертов по 7 ключевым метрикам; написание Runbook (RUNBOOK-01..07); внедрение регламентов управления инцидентами, изменениями, уровнем услуг; обучение команды	Месяц 5–6	Дашборд мониторинга, алерты, Runbook, утверждённые регламенты ITIL

4	Тестирование и пилот	Нагрузочное тестирование (jMeter / Locust); тест восстановления из бэкапа (DR drill); UAT с группой из 20–30 реальных трейдеров; исправление критических дефектов	Месяц 6	Отчёт по нагрузочному тестированию, подтверждённый SLA Uptime $\geq$ 99.5%, пройденный DR drill
5	Коммерческий запуск	Публичный запуск; SEO-оптимизация; публикация в тематических сообществах; подключение первых B2B-клиентов; запуск Premium-подписки	Месяцы 7–8	Первые платящие пользователи, MRR > 0, MAU > 500
6	Стабилизация и оптимизация	Анализ первых инцидентов; ретроспектива; оптимизация производительности LSTM/SARIMA; расширение на Dota 2 / TF2; пересмотр SLA; подготовка к масштабированию Y2	Месяцы 9–12	Стабильный MAU 3 000, MAPE $\leq$ 10%, отсутствие P1-инцидентов дольше 30 мин

4.3 Управление рисками проекта

№	Риск	Вероятность	Влияние	Меры по снижению
---	------	-------------	---------	------------------

Риск 1	Блокировка / ограничение Steam API (изменение политики Valve, введение платного API, смена формата ответов)	Средняя	Критическое: полная остановка сбора данных → деградация MAPE → невозможность оказания услуги	Кэш scraped_data/ с retention 30 дней покрывает до 30 дней без обновлений. Интеграция резервных источников (Skinport API, Buff163 API) — прорабатывается параллельно с основным запуском. Мониторинг Steam API Success Rate с автоматическим fallback
Риск 2	Срыв сроков финализации MVP (недооценка объёма работ по UI, биллингу, аккаунтам)	Средняя	Высокое: задержка коммерческого запуска, упущенное first-mover преимущество, сдвиг окупаемости	Приоритизация: сначала core-фича (прогнозирование) + минимальный биллинг; UI и дополнительные функции — итерациями. Буфер 2 недели в каждом этапе. Еженедельный статус с Владелецem сервиса

Риск 3	Инцидент безопасности при запуске (компрометация учётных данных, утечка API-ключей из-за давления по срокам)	Средняя	Высокое: репутационный ущерб критичен для стартапа; потеря B2B-клиентов; юридические риски (ФЗ-152)	Security checklist как gate перед переходом в production (MFA облачной панели, vault для секретов, DR drill, ограничение SSH по IP). Разделение ответственности: DevOps не имеет доступа к продакшн-БД без согласования Владельца
Риск 4	Недостижение плановых показателей MAU и конверсии в Y1	Средняя	Среднее: замедление роста MRR, пересмотр бюджета Y2	Контрольные точки каждые 3 месяца: при отклонении MAU > 20% от плана — пересмотр маркетинговой стратегии. Pivot-plan: фокус на B2B-сегменте при медленном B2C-росте

Риск 5	Деградация качества прогнозов (MAPE > 25%) после крупного обновления Valve	Средняя	Высокое: основной value proposition подорван; отток пользователей	Автоматический еженедельный бэкtest по топ-20 предметам. Алерт MAPE > 15% (warn) с запуском retraining. Алерт MAPE > 25% (critical) — смена модели по умолчанию
---------------	--	---------	---	---

4.4 Коммуникации

Заинтересованные стороны (Stakeholders)

Стейкхолдер	Интерес в проекте	Уровень влияния
Владелец сервиса	Успешный коммерческий запуск, ROI, MAU, MRR	Высокий
Команда разработки (backend, ML, DevOps)	Технические решения, качество кода, SLA	Высокий
B2B-клиенты (трейдинговые боты, арбитражные сервисы)	Стабильность API, SLA, тарифы	Высокий
B2C-пользователи (трейдеры, коллекционеры)	Точность прогнозов (MAPE), UX, доступность	Средний
Облачный провайдер (Yandex Cloud / Selectel / Hetzner)	Использование ресурсов, оплата	Низкий
Инвестор / ментор (при наличии)	ROI, соблюдение плана, финансовая отчётность	Высокий

Каналы и регламент коммуникаций

Аудитория	Канал	Формат	Периодичность
Вся команда	Telegram-группа проекта	Оперативные обновления, алерты	Ежедневно
Вся команда	Еженедельный супс (Zoom / Google Meet)	Статус задач, блокеры, решения	Еженедельно, по понедельникам
Владелец сервиса + команда	Jira / Linear	Трекинг задач, статус этапов плана	Постоянно
В2В-клиенты	Email + Telegram Support	SLA-отчёты, уведомления об обслуживании	Ежемесячно + по инцидентам $\geq$ P2
В2С-пользователи	Email-рассылка + статусная страница	Плановые работы, крупные обновления	По мере необходимости
Владелец / инвестор	Email-отчёт	Финансовые метрики (MRR, MAU, MAPE, Uptime), TCO vs план	Ежеквартально
Команда	Postmortem-документ (Confluence / Notion)	Разбор P1-инцидентов	После каждого P1-инцидента

Отчётность по SLA формируется в течение 3 рабочих дней после окончания отчётного месяца и направляется В2В-клиентам автоматически через шаблон из регламента управления уровнем услуг.